



— AXE A · LES COMPTES ET LES GROUPES

Tout le monde peut fabriquer un ordinateur

Le chiffre 10 qui dort dans votre annuaire — et ce qu'il offre, gratuitement, à n'importe quel utilisateur.

Posez la question lors de votre prochaine réunion d'équipe : « chez nous, qui peut ajouter un ordinateur au domaine ? » La réponse fusera, unanime. Et elle sera fausse. Cette fiche démonte une croyance si banale qu'on ne la questionne jamais — et vous montre, commande à l'appui, comment refermer en quelques minutes une porte que votre Active Directory tient ouverte depuis le jour de son installation.

■ L'IDÉE REÇUE

« Seuls les administrateurs peuvent ajouter une machine au domaine. »

En réalité — par défaut, n'importe quel utilisateur authentifié de votre domaine peut créer jusqu'à **dix comptes ordinateurs** dans l'annuaire. Sans validation, sans alerte. Ce n'est pas un bug : c'est un réglage hérité de l'an 2000 que personne n'a jamais refermé.

L'ÉDITO DU NUMÉRO 01

Bienvenue dans le premier numéro d'AD-Compagnon. Ce magazine est né d'un constat simple : la sécurité d'Active Directory se raconte trop souvent en anglais, en surface, ou dans un jargon qui décourage. Ici, nous prenons le temps de l'inverse — un sujet par mois, creusé jusqu'à la salle des machines, mais raconté pour être compris. Chaque fiche part d'une idée reçue du quotidien et vous promet, quelque part en chemin, un « ça, je ne le savais pas ». Commençons par un chiffre que vous avez sous les yeux depuis des années sans jamais l'avoir vraiment regardé.

— Yeni DOUKAKAS

AU SOMMAIRE DE CETTE FICHE

1 Le déclic
L'idée reçue, l'analogie et l'impact métier — sans jargon.

2 Le mécanisme
L'attribut, les deux verrous, ce qui se passe à la création.

3 La salle des machines
Vérifier, comprendre l'attaque, corriger et détecter.

1 NIVEAU 1 — POUR COMPRENDRE

Le déclic

Reprenons cette question de réunion : « chez nous, qui peut ajouter un ordinateur au domaine ? » La réponse spontanée sera presque toujours « les administrateurs, bien sûr ». Elle est fausse. Et cette croyance n'est pas une simple coquetterie de vocabulaire : c'est une porte de service que votre annuaire laisse entrebâillée depuis sa toute première heure de fonctionnement.

Imaginez un immeuble de bureaux dont le règlement intérieur, rédigé en 2003 et jamais relu, autorise chaque locataire à faire fabriquer — discrètement, sans rien demander à personne — jusqu'à dix badges d'accès supplémentaires. Pendant des années, personne ne s'en sert vraiment. La vie de l'immeuble suit son cours paisible.

Jusqu'au jour où un occupant mal intentionné réalise que ces badges, parfaitement anodins en

apparence, ouvrent en réalité des portes de service qu'il n'aurait jamais dû pouvoir approcher. Dans Active Directory, ce badge porte un nom précis : le **compte ordinateur**.

Et un compte ordinateur n'est pas un objet de second rang. C'est une identité à part entière : il s'authentifie, reçoit des tickets Kerberos, peut se voir attribuer des droits. Surtout — détail décisif — c'est l'utilisateur qui crée la machine qui en **définit le mot de passe**. Il le connaît donc.

Dès la première seconde, un compte sans le moindre privilège dispose ainsi d'une identité-machine entièrement sous son contrôle. Pour un attaquant, ce n'est pas un détail anodin : c'est un capital de départ, offert gracieusement par la configuration par défaut. La suite de cette fiche vous montre exactement ce qu'il en fait — et comment lui retirer ce cadeau.

« Un compte ordinateur n'est pas un objet de second rang : c'est une identité à part entière, capable de servir de pivot. »

Le calcul qui dérange

x10

Multipliez le nombre de comptes actifs de votre domaine par dix : vous obtenez le nombre de comptes ordinateurs qui peuvent y être créés **aujourd'hui** — sans privilège, sans validation, sans la moindre alerte.

POURQUOI ÇA COMPTE — L'IMPACT MÉTIER

La question n'est pas théorique. Chaque compte de service applicatif, chaque compte utilisateur dormant, chaque stagiaire dispose aujourd'hui, sur votre domaine, du droit de créer dix machines. Si l'un de ces comptes est compromis — un mot de passe faible, un hameçonnage réussi — l'attaquant hérite immédiatement de cette capacité. Il n'a pas besoin d'être administrateur : la configuration par défaut lui tend déjà l'outil. Refermer cette porte ne coûte rien et ne casse rien. Encore faut-il savoir qu'elle existe.

2

NIVEAU 2 — LE FONCTIONNEMENT RÉEL

Le mécanisme

Tout en haut de votre domaine se trouve un objet discret : l'objet `domainDNS`, la racine même de la partition d'annuaire. Il porte des dizaines d'attributs. L'un d'eux se nomme `ms-DS-MachineAccountQuota` ; sa valeur par défaut, inchangée depuis l'ère Windows 2000, est de **dix**.

Mais attention à une confusion presque universelle : la capacité de créer un compte ordinateur ne dépend pas d'un seul réglage. Elle dépend de **deux verrous distincts**, qui doivent être ouverts tous les deux.

VERROU 1 — LE DROIT

« Ajouter des stations de travail au domaine »

Ce droit utilisateur (privilège `SeMachineAccountPrivilege`) est, par défaut, accordé au groupe « Utilisateurs authentifiés » via la stratégie des contrôleurs de domaine. En pratique : à tout le monde.

VERROU 2 — LE QUOTA

L'attribut `ms-DS-MachineAccountQuota`

Il plafonne le nombre de machines qu'un détenteur du droit ci-contre peut créer. Réglé sur 10, il autorise dix créations par compte. Réglé sur 0, il referme la porte.

Tant que les deux verrous restent ouverts — droit accordé à tous, quota à 10 — chaque compte du domaine peut fabriquer ses dix ordinateurs. Que se passe-t-il alors au moment précis de la création ? Le contrôleur de domaine inscrit le SID du créateur dans l'attribut `ms-DS-CreatorSID` du nouvel objet : une signature indélébile. Le créateur, lui, définit le mot de passe du compte machine. Et l'objet, sauf redirection explicite, atterrit dans le conteneur par défaut `CN=Computers` — un emplacement que peu d'administrateurs pensent à surveiller.



! Résultat — un compte sans le moindre privilège obtient une identité-machine entièrement sous son contrôle.

Schéma 1 — Comment naît un compte ordinateur, et où se situent les deux verrous.

SOUS L'ÉCORCE

« Mais si je passe le quota à zéro, je casse tout mon déploiement automatisé ! » — Rassurez-vous : c'est faux, et c'est même une excellente nouvelle. Le quota ne plafonne *que* les détenteurs du droit « Ajouter des stations de travail au domaine ». Un compte à qui vous avez délégué **explicitement** la permission « Créer des objets Ordinateur » sur une unité d'organisation n'y est pas soumis du tout. Votre chaîne de provisioning — SCCM/MECM, Autopilot, compte de jonction dédié — continue de fonctionner sans broncher, quota à zéro ou non. Les deux mécanismes sont indépendants : c'est précisément ce qui rend la correction parfaitement sûre.

3

NIVEAU 3 — SUR LE TERRAIN

La salle des machines

Trois gestes, toujours dans le même ordre : **vérifier** la configuration chez soi, **comprendre** ce qu'un attaquant en ferait, puis **corriger et détecter**. Aucun ne demande plus de quelques minutes.

1 Vérifier

Commençons par le diagnostic. Une seule commande PowerShell lit l'attribut directement à la racine de votre domaine — à exécuter depuis un poste disposant du module Active Directory (RSAT).

LA COMMANDE DU JOUR — VÉRIFIER LE QUOTA

```
PS C:\> Get-ADObject -Identity (Get-ADDomain).DistinguishedName `
           -Properties ms-DS-MachineAccountQuota
```

Mot à mot. `(Get-ADDomain).DistinguishedName` récupère le chemin de l'objet racine du domaine ; `Get-ADObject` lit cet objet ; `-Properties` réclame l'affichage de l'attribut, que PowerShell ne montre pas par défaut. Si la réponse affiche **10** — ou toute valeur supérieure à zéro — le verrou est ouvert.

```
Administrateur : Windows PowerShell

PS C:\> Get-ADObject -Identity (Get-ADDomain).DistinguishedName `
>>      -Properties ms-DS-MachineAccountQuota

DistinguishedName      : DC=adcompagnon,DC=lab
ms-DS-MachineAccountQuota : 10
Name                    : adcompagnon
ObjectClass              : domainDNS

PS C:\>
```

! Le verrou est ouvert

La valeur 10 confirme que tout utilisateur peut créer jusqu'à dix comptes ordinateurs — sans validation ni journalisation.

Capture simulée — la sortie de la commande sur le domaine fictif `adcompagnon.lab`.

2 Comprendre l'attaque

Le quota n'est pas une vulnérabilité en lui-même. C'est un **facilitateur** : il distribue gratuitement l'ingrédient de base de plusieurs chemins d'attaque parmi les plus utilisés sur Active Directory. Deux exemples, au niveau du principe.

CE QU'UN ATTAQUANT EN FAIT

La délégation contrainte basée sur les ressources (RBCD)

Plusieurs techniques d'élévation de privilèges réclament un compte ordinateur dont l'attaquant maîtrise le mot de passe, pour lui faire jouer le rôle du « service » dans une relation de délégation Kerberos. Le quota fournit exactement cela : une machine contrôlée, créée en une commande. Couplée à un droit d'écriture sur une machine cible, elle permet d'obtenir un ticket de service au nom d'un compte privilégié. *Le mécanisme complet de la délégation fera l'objet d'une fiche dédiée.*

L'usurpation de nom de compte (famille « noPac »)

Référencée sous les CVE-2021-42278 et 42287, elle crée une machine grâce au quota, lui donne le nom d'un contrôleur de domaine — sans le caractère `$` final — puis exploite la résolution de noms du KDC pour obtenir un ticket au nom du véritable contrôleur. Les correctifs de novembre 2021 referment ce chemin ; le quota, lui, reste l'amorce.

Dans les deux cas, la logique est la même — **retirez le quota, et vous retirez l'amorce.**

3 Corriger et détecter

La correction tient en trois gestes — sans budget, sans projet, sans fenêtre de maintenance. C'est le bloc le plus important de cette fiche : on ne quitte jamais un problème sans sa solution.

1 Refermer le verrou

Passez la valeur du quota à zéro. Plus aucun détenteur du simple droit « Ajouter des stations » ne pourra créer de machine.

● ● ● APPLIQUER LA CORRECTION

```
PS C:\> Set-ADDomain -Identity (Get-ADDomain).DistinguishedName `
    -Replace @{"ms-DS-MachineAccountQuota"="0"}
```

2 Rendre la jonction au domaine explicite

Retirez le groupe « Utilisateurs authentifiés » du droit « Ajouter des stations de travail au domaine » (dans la stratégie des contrôleurs de domaine), puis déléguez à un **groupe dédié** la permission « Créer des objets Ordinateur » sur les unités d'organisation prévues pour les postes. Votre processus de déploiement utilise ce groupe ; plus personne d'autre ne crée de machine.

3 Faire le ménage

Recherchez les comptes ordinateurs déjà créés par des utilisateurs ordinaires — leur attribut **ms-DS-CreatorSID** est renseigné — et vérifiez leur légitimité avant de les supprimer.

Détecter — les bons événements

Activez l'audit « Gestion des comptes d'ordinateurs » et surveillez deux événements sur vos contrôleurs de domaine.

ID 4741 « Un compte d'ordinateur a été créé ». Le champ **Sujet** révèle le créateur : un compte utilisateur ordinaire à cet endroit — et non votre compte de provisioning — mérite une investigation immédiate.

ID 4781 « Le nom d'un compte a été modifié ». Un compte machine renommé pour ressembler à un contrôleur de domaine est un signal d'alerte fort : c'est la signature de la variante noPac.

Pour une **chasse proactive**, cette commande liste les comptes ordinateurs portant la signature d'un créateur :

● ● ● CHASSE — COMPTES MACHINES CRÉÉS PAR UN UTILISATEUR

```
PS C:\> Get-ADComputer -Filter * -Properties ms-DS-CreatorSID,whenCreated |
    Where-Object { $_.'ms-DS-CreatorSID' } |
    Select-Object Name, whenCreated, ms-DS-CreatorSID
```

OBSERVATEUR D'ÉVÉNEMENTS — JOURNAL SÉCURITÉ

Event ID 4741

Tâche : Gestion des comptes d'ordinateurs

Sujet : ADCOMPAGNON\j.martin ← un utilisateur ordinaire, pas un compte de provisioning

Nouveau : Nom du compte d'ordinateur = PC-ADC-WS47\$

Attributs : SAM Account Name = PC-ADC-WS47\$

! Créateur inattendu — à corrélér avec les habilitations et la chaîne de déploiement.

VU SUR LE TERRAIN

Lors de l'audit d'un groupe industriel, l'équipe sécurité repère dans les journaux d'une nuit douze comptes ordinateurs créés en quelques minutes — tous par le même compte de service applicatif. Ce compte n'avait aucune raison de fabriquer des machines : il avait été compromis quelques heures plus tôt, et le quota par défaut venait de lui offrir, sans aucun privilège supplémentaire, la rampe de lancement d'une attaque par délégation. Coût de la prévention : la modification d'un attribut. Coût de l'incident : une cellule de crise et trois nuits blanches.

LE COIN DU DÉCIDEUR

Cette correction ne réclame ni budget, ni projet, ni fenêtre de maintenance : c'est une **décision**, applicable en quelques minutes. La bonne question à poser à votre équipe n'est donc pas « est-ce risqué de le faire ? », mais « **depuis combien d'années laissons-nous ce verrou ouvert ?** ». C'est l'archétype de la dette de configuration : invisible au bilan, parfaitement visible pour un attaquant. Inscrivez la valeur **ms-DS-MachineAccountQuota = 0** dans votre socle de durcissement, et faites-la vérifier comme on vérifie une serrure — régulièrement.

L'ÉNIGME DU COMPAGNON — N°01

Sur le domaine `adcompagnon.lab`, un compte nommé **j.martin** — simple utilisateur, aucun privilège — vient de créer un compte ordinateur. Détail troublant : il l'a baptisé **ADC-DC01**, soit exactement le nom d'un contrôleur de domaine... mais en « oubliant » le caractère `$` final. **Pourquoi l'équipe Active Directory devrait-elle, ce soir, annuler ses plans ?**

LA RÉPONSE DU COMPAGNON

Parce que ce n'est pas un oubli. En nommant sa machine comme un contrôleur de domaine privé de son `$`, j.martin pose la première pièce de l'attaque **noPac** : il pourra obtenir un ticket Kerberos pour ce compte, puis le renommer, de sorte que le KDC — ne trouvant plus le compte exact — complète le nom et délivre un ticket au nom du véritable contrôleur de domaine. Si `adcompagnon.lab` n'a pas reçu les correctifs de novembre 2021, c'est une élévation directe vers les clés du royaume. Le quota à 10 lui a fourni la machine ; le correctif manquant ferait le reste.

LE GLOSSAIRE

Active Directory (AD) — l'annuaire qui gère les identités, les machines et les droits d'un réseau Windows.

Contrôleur de domaine (DC) — le serveur qui héberge cet annuaire et valide les authentifications.

Compte ordinateur — l'identité que possède toute machine jointe au domaine ; un compte à part entière, dont le nom se termine par `$`.

Attribut — un champ d'information porté par un objet de l'annuaire ; ici, le quota.

SID — l'identifiant unique et immuable d'un compte ou d'un groupe.

KDC — le composant du contrôleur de domaine qui délivre les tickets Kerberos.

Ticket Kerberos — le « laissez-passer » obtenu après authentification, présenté pour accéder aux services.

RBCD — délégation contrainte basée sur les ressources : un mécanisme Kerberos autorisant un compte à agir « au nom de » un autre.

Event ID — le numéro qui identifie un type d'événement dans les journaux Windows.

RSAT — les outils d'administration distante qui fournissent, entre autres, le module PowerShell Active Directory.



DANS LE PROCHAIN NUMÉRO

N°02 — Kerberos : la délégation, ce pouvoir que vous avez accordé sans le savoir

Comment trois cases à cocher transforment un serveur ordinaire en passe-partout du domaine.